

Autenticação de APIs

Tokens, OAuth 2.0, JWT e controles de acesso em APIs.

Autenticação × autorização

Autenticação comprova identidade; autorização determina o que aquela identidade pode acessar.

OAuth 2.0 e tokens

Em APIs modernas, tokens de acesso são comuns. QA deve validar token ausente, inválido, expirado, escopos incorretos e renovação quando aplicável.

JWT

JWT é um formato de token. Valide assinatura, expiração, claims e comportamento da API; nunca trate apenas a decodificação do payload como prova de validade.

QA Tip

Inclua testes negativos de autenticação em toda API protegida.

Official: <https://datatracker.ietf.org/doc/html/rfc6749>